

# Refine — IAM Permissions Reference

**Purpose:** AWS Marketplace reviewers and customer security teams need to know exactly what IAM permissions the Refine CloudFormation stack creates in the customer's account. This document is the authoritative reference.

Refine is **read-only by design**. Across both the host stack (Marketplace-deployed) and the per-account onboarding stack (added once per AWS account being monitored), Refine never requests, accepts, or uses write permissions on customer cloud resources.

## Stack A — Marketplace Host Stack ( `refine-marketplace-cfn.yaml` )

This is the stack the customer launches from the AWS Marketplace listing. It provisions the Refine EC2 host in the customer's account.

### IAM resources created

| Resource                           | Type                                   | Purpose                                                                                                                                                                                                                                                 |
|------------------------------------|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>RefineInstanceRole</code>    | <code>AWS::IAM::Role</code>            | Attached to the Refine EC2 instance. Grants only the minimum needed to verify the AWS Marketplace entitlement via AWS License Manager and run SSM Session Manager (plus, on the BYOL / direct-sales & GovCloud path only, read of the delivery bucket). |
| <code>RefineInstanceProfile</code> | <code>AWS::IAM::InstanceProfile</code> | Wraps the role for EC2 attachment.                                                                                                                                                                                                                      |

The customer may bring their own existing instance profile via the `ExistingInstanceProfileArn` parameter, in which case the CFN creates **no** IAM resources.

### Inline policy attached to `RefineInstanceRole`

This is the **default** policy — the public AWS Marketplace path. It verifies the Marketplace contract entitlement via AWS License Manager and enables SSM Session Manager.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "MarketplaceEntitlement",
      "Effect": "Allow",
      "Action": [
        "license-manager:CheckoutLicense",
        "license-manager:GetLicense",
        "license-manager:CheckInLicense",
        "license-manager:ExtendLicenseConsumption",
        "license-manager:ListReceivedLicenses",
        "license-manager:GetEntitlements"
      ],
      "Resource": "*"
    },
    {
      "Sid": "SSMSessionManager",
      "Effect": "Allow",
      "Action": [
        "ssm:UpdateInstanceInformation",
        "ssmmessages:CreateControlChannel",
        "ssmmessages:CreateDataChannel",
        "ssmmessages:OpenControlChannel",
        "ssmmessages:OpenDataChannel",
        "ec2messages:GetMessages",
        "ec2messages:AcknowledgeMessage",
        "ec2messages:DeleteMessage",
        "ec2messages:FailMessage",
        "ec2messages:GetEndpoint",
        "ec2messages:SendReply"
      ],
      "Resource": "*"
    }
  ]
}
```

The `license-manager:*` actions use `Resource: "*"` because they don't support resource-level scoping; access is gated by the product + the buyer's contract.

Plus AWS-managed policies:

- `AmazonSSMManagedInstanceCore` — for SSM Session Manager browser-based SSH.

Plus, for the **BYOL / direct-sales & GovCloud fulfillment path only** (not the public Marketplace contract path) — read access to the customer's own delivery bucket so the on-host license-watcher can pull the signed `refine.license` (and, for air-gapped GovCloud, the delivery ZIP). On this path the `license-manager` statement above has no effect and can be omitted:

```
{
  "Sid": "ReadDeliveryBucket",
  "Effect": "Allow",
  "Action": [
    "s3:GetObject",
    "s3:ListBucket",
    "s3:GetBucketLocation"
  ],
  "Resource": [
    "arn:aws:s3:::<delivery-bucket>",
    "arn:aws:s3:::<delivery-bucket>/*"
  ]
}
```

**That's it.** The Refine container does not assume any IAM role to query customer cloud resources. Cloud-account onboarding is a separate, customer-initiated stack per account (Stack B below).

### Non-IAM resources the stack creates (for completeness)

- 1× EC2 instance (default `t3.medium`, customer-sizable up to `m6i.4xlarge`).
- 1× EBS root volume (default 30 GB gp3).
- 1× S3 bucket for the delivery ZIP (customer-named or auto-named) — **BYOL / direct-sales & GovCloud only; not created on the public Marketplace contract path.**
- 1× Security Group (inbound: SSH from `AllowedSshCidr`, app port 8000 from `AllowedAppCidr`).
- Optional: 1× Elastic IP.
- Optional: 1× Application Load Balancer + ACM listener + target group + ALB Security Group (when `EnableHttps=true`).

No Lambda, no IAM users, no IAM access keys, no Secrets Manager secrets.

## Stack B — Per-Account Onboarding Stack ( `customer-onboarding-v2.yaml1` )

This stack is launched once **per AWS account the customer wants Refine to monitor**. It's separate from the Marketplace stack and gets launched from inside the running Refine UI (Cloud Accounts → Add Account → click "Launch CloudFormation"). Marketplace doesn't ingest this template directly, but reviewers commonly ask about it.

### IAM resources created

| Resource                               | Type                                 | Purpose                                                                                                         |
|----------------------------------------|--------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| <code>RefineCollectorRole</code>       | <code>AWS::IAM::Role</code>          | Assumed by the Refine host's instance role (cross-account, ExternalID-protected) to read inventory + cost data. |
| <code>RefineCollectorPolicy</code>     | <code>AWS::IAM::ManagedPolicy</code> | Attached to the role. Read-only across the AWS services Refine analyzes.                                        |
| <code>RefineCollectorLambdaRole</code> | <code>AWS::IAM::Role</code>          | Execution role for the per-account collector Lambda (writes summaries to the customer's own S3 bucket).         |

## Read-only permissions granted to `RefineCollectorRole`

The role grants `Read*`, `List*`, `Get*`, `Describe*` only — **never** `Create*`, `Update*`, `Modify*`, `Delete*`, `Put*` (except `s3:PutObject` on the customer-owned summary bucket, scoped to that one bucket).

Services covered (one read-only block per service):

| Category                          | Service                                      | Actions                                                                                                                                                                                                                                                      |
|-----------------------------------|----------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cost                              | Cost Explorer, Cost & Usage Reports, Budgets | <code>ce:Get*</code> , <code>ce:Describe*</code> , <code>cur:DescribeReportDefinitions</code> , <code>budgets:Describe*</code> , <code>budgets:View*</code>                                                                                                  |
| Compute                           | EC2, EBS                                     | <code>ec2:Describe*</code> , <code>ec2:GetEbsEncryptionByDefault</code>                                                                                                                                                                                      |
| Database                          | RDS                                          | <code>rds:Describe*</code> , <code>rds:ListTagsForResource</code>                                                                                                                                                                                            |
| Storage                           | S3                                           | <code>s3:ListAllMyBuckets</code> , <code>s3:GetBucketLocation</code> , <code>s3:GetBucketTagging</code> , <code>s3:GetBucketPolicyStatus</code> , <code>s3:GetBucketLifecycleConfiguration</code> , <code>s3:GetBucketIntelligentTieringConfiguration</code> |
| Network                           | ELB, NAT, VPC                                | <code>elasticloadbalancing:Describe*</code> , <code>ec2:Describe*</code> (NAT/EIP/VPC)                                                                                                                                                                       |
| Serverless                        | Lambda                                       | <code>lambda:List*</code> , <code>lambda:Get*</code>                                                                                                                                                                                                         |
| Containers                        | ECS, Fargate                                 | <code>ecs:Describe*</code> , <code>ecs:List*</code>                                                                                                                                                                                                          |
| Cache                             | ElastiCache                                  | <code>elasticache:Describe*</code>                                                                                                                                                                                                                           |
| Misc                              | Batch, Lightsail                             | <code>batch:Describe*</code> , <code>lightsail:Get*</code>                                                                                                                                                                                                   |
| Monitoring                        | CloudWatch                                   | <code>cloudwatch:GetMetricStatistics</code> , <code>cloudwatch:GetMetricData</code> , <code>cloudwatch:ListMetrics</code> , <code>logs:Describe*</code>                                                                                                      |
| Identity (for boundary detection) | STS                                          | <code>sts:GetCallerIdentity</code>                                                                                                                                                                                                                           |
| Savings Plans / RI                | Savings Plans, EC2                           | <code>savingsplans:Describe*</code> , <code>savingsplans:List*</code> , <code>ec2:Describe*ReservedInstances*</code>                                                                                                                                         |
| Write — single exception          | S3 (own bucket only)                         | <code>s3:PutObject</code> , <code>s3:DeleteObject</code> scoped to <code>arn:aws:s3:::&lt;summary-bucket&gt;/*</code>                                                                                                                                        |

## Trust policy

The role can only be assumed by:

- The Refine host's instance role ARN (provided as a CFN parameter at launch).
- With a matching `sts:ExternalId` value (random per customer; provided in the Refine UI).

This is the standard third-party cross-account access pattern documented at [https://docs.aws.amazon.com/IAM/latest/UserGuide/id\\_roles\\_create\\_for-user\\_externalid.html](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_create_for-user_externalid.html).

## Per-account collector Lambda

The Lambda runs in the customer's AWS account on a nightly EventBridge schedule. Its execution role grants:

- The same read-only service permissions listed above.
- `s3:PutObject` to the customer-owned summary bucket.
- `logs:CreateLogGroup`, `logs:CreateLogStream`, `logs:PutLogEvents` (for its own CloudWatch logs).
- Nothing else.

No outbound network calls outside AWS. No third-party SDKs.

---

## Stack C — GovCloud Onboarding Stack ( `customer-onboarding-govcloud.yaml` )

Identical to Stack B with two differences:

- Partition switched to `aws-us-gov` throughout the IAM resource ARNs.
  - The Cost Explorer / Cost & Usage Reports permissions are **dropped** (those services don't exist in AWS GovCloud).
- 

## Verification commands (for the customer's security team)

After Stack A is deployed, the customer can verify the host's permissions:

```
# What the EC2 instance role can do – should be only the S3+SSM list above.
aws iam list-attached-role-policies --role-name RefineInstanceRole
aws iam list-role-policies --role-name RefineInstanceRole
aws iam get-role-policy --role-name RefineInstanceRole --policy-name <inline-policy-name>
```

After Stack B is deployed in a monitored account:

```
# Confirm the role is read-only – should return zero write actions outside the summary bucket.
aws iam get-role --role-name RefineCollectorRole
aws iam list-attached-role-policies --role-name RefineCollectorRole
aws iam get-policy-version --policy-arn <RefineCollectorPolicy ARN> --version-id v1
```

For an automated audit, IAM Access Analyzer should report **zero external access risk** on either role beyond the explicitly intended cross-account trust to the Refine host.

---

## Why this matters for AWS Marketplace review

- Refine ships **zero write permissions** on customer resources outside of writing summary files to a bucket the customer owns. This is the foundational claim of the product.
- The Marketplace host stack creates **no IAM permissions for the customer's monitored cloud accounts**. Customers explicitly opt-in by launching Stack B in each account.
- Cross-account access uses **the AWS-recommended ExternalID pattern** with rotating IDs per customer.
- All customer cost/inventory data lives **in the customer's own S3 / Blob / GCS bucket** — Refine reads from there. Blacktip Solutions has no network path to customer data.

